

Active Directory Intro, Authentication, Windows Server Concepts, and Network Services

These notes were written by Kevin Beideman. The recommended time to understand and practice these concepts is 2 hours.

Active Directory

What is Active Directory?

A centralized directory and identity management system created by Microsoft that organizations use to manage users, computers, servers, permissions, and security policies across a network. So, one centralized server stores identities, users can log into multiple systems with the same credentials, and admins can control access across the organization.

What problem does Active Directory solve?

*Before AD: Every computer, user account, password, and permission had to be managed separately. This was impossible to scale as companies grew. SO, AD solves the problem of **Centralized Management**.*

What is a domain in Windows?

*A domain is a centralized network environment where users, computers, and security policies are managed together through Active Directory. Domain Ex: **lasalle.local** Inside this domain, student accounts, professor accounts, lab computers, servers, printers, and shared drives are all managed centrally.*

Domain Controller (DC): A Windows server that runs Microsoft Active Directory services and manages authentication, authorization, and security policies for a domain. It stores: user accounts, password hashes, computer accounts, group memberships, and security policies.

Domain: Read above

Organizational Unit (OU): A container inside Active Directory used to organize users, groups, and computers. Ex: HR, Finance, IT, Students, Faculty.

Group Policy: A Windows feature that allows administrators to centrally enforce settings and security configurations across domain computers and users.

LDAP: Lightweight Directory Access Protocol: A protocol used to communicate with directory services like Active Directory. LDAP allows systems to query user information, authenticate users, search directory objects, and retrieve permissions/groups.

Kerberos: Primary authentication protocol used in Active Directory environments. Instead of repeatedly sending passwords over the network, Kerberos uses encrypted “tickets” to verify identity securely.

How does a Windows domain environment work?

It works by centralizing authentication, identity management, permissions, and security policies through Microsoft Active Directory and Domain Controllers.

Step 1: User Enters Credentials. Workstation does not fully authenticate locally; it contacts the Domain Controller.

Step 2: Authentication Request: The computer sends the login request to the DC using Kerberos.

Step 3: Kerberos Ticket Issues. If authentication succeeds: the DC issues Kerberos tickets and the user receives a Ticket Granting Ticket.

Step 4: Access to Resources: When accessing shared drivers, printers, email, and internal apps, the user presents Kerberos tickets instead of retyping passwords repeatedly.

Authentication + Enterprise Security

What is authentication?

The process of verifying who someone is. “Are you really who you claim to be?”

What is authorization?

The process of determining what an authenticated user is allowed to access or do. “What are you allowed to do?”

Basically: proving identity vs determining permissions

Kerberos is the authentication protocol used in Microsoft Windows domain environments. It is a ticket-based authentication system. It helps avoid constantly sending passwords, centrally verifying identity, and securely authenticating users.

NTLM: NT LAN Manager, An older authentication protocol used in Windows environments before Kerberos became the default in Microsoft Active Directory domains. It verifies identity using a challenge-response authentication process. Instead of sending the actual password, the server sends a challenge and the client responds using cryptographic calculations based on the password hash.

LDAP: Lightweight Directory Access Protocol. They commonly store User Accounts. Ex: jdoe, asmith, administrator. Also, Groups, Computers, OUs, and Security Information.

Password Hashing and Salting: Hashing is the process of converting a password into a fixed-length string of characters using a mathematical algorithm called a hash function. Salting

is a random value added to a password before hashing. Example: Password is 123! And Salt is: 229328. Those are combined, and then hashed. The password hashes are heavily targeted by attackers as they don't need the actual plaintext passwords to cause damage. With the hashes, they can crack passwords offline, impersonate users, move laterally, escalate privileges, and access enterprise systems.

Windows Networking Services Deep Dive

DNS is critical in Active Directory because it heavily depends on it to: locate Domain Controllers, authenticate users, find services, and communicate across the domain. Without it: logins can fail, Group Policy may fail, domain communication breaks, and authentication problems occur. When a workstation tries to log into a domain: "company.local", it must find: A Domain Controller. It does this using DNS. If a user logs in as jdoe, the computer asks DNS where is the domain controller for this domain. DNS provides: service name, IP address, and AD service records. Now the workstation is able to contact the DC, use Kerberos, and authenticate the user.

Remember that DHCP (Dynamic Host Configuration Protocol) is a network management protocol that automatically assigns IP addresses. So, enterprises use DHCP to automatically assign network settings to devices on the network. There is no need to manually configure every computer.

A DHCP reservation permanently assigns a specific IP address to a specific device based on its MAC address. So if we have a printer's mac address with a reserved IP, when that printer connects it always receives the same IP.

SMB: (Server Message Block), network protocol used for file sharing, printer sharing, network communication, and remote access to shared resources. In enterprises, SMB is used for shared department drives, centralized file servers, printer sharing, administrative management, backups, and software deployment. SMB shares are folders or resources made available over the network using SMB protocol.

RDP: Remote Desktop Protocol, protocol that allows users to remotely control another computer over a network. So, someone can see the remote computer's desktop, use its keyboard/mouse, open files/programs, and administer systems. Well, it is targeted by attackers because they can just control the machine....lol. They can do whatever they want with it.

Lateral movement is when an attacker moves from one compromised system to other systems inside a network after gaining initial access. So, he/she will spread through the environment to reach valuable systems, steal credentials, escalate privileges, access sensitive data, and eventually control the network. AD is a target of this as it controls identities, authentication, permissions, systems, users, and enterprise access.

Powershell Enumeration + Admin Workflow

In Powershell: run **whoami**, then **net user**. This command shows user accounts by default.

Now: **whoami /groups**. This argument displays all security groups associated with the currently logged-in user. Security groups are collections of users or computers used to manage permissions and access control more efficiently.

Try: **net localgroup administrators**. This displays the members of the local Administrators group on the computer.

Try: **net share**. Displays all SMB shares available on the local computer.